

El presente informe consolida las pruebas de seguridad realizadas sobre Constata (constata.dev) el **17 de septiembre de 2026**. Se evaluaron tres frentes con tres herramientas de uso libre —**Trivy**, **Semgrep** y **Gitleaks**— y se sumó una cuarta revisión sobre la configuración con la que el sitio atiende al público. Se detectaron **tres fallos** en esa configuración y **un aviso** en una dependencia. Todos los resultados son reproducibles.

ALCANCE Y RESULTADOS

FRENTE EVALUADO	HERRAMIENTA	QUÉ SE REVISÓ	RESULTADO
Sitio publicado	pruebas en vivo	la configuración con la que el sitio responde a quien lo visita	3 fallos · hallazgos 1, 2 y 3
Composición	Trivy 0.74	los 95 programas de terceros que el proyecto trae consigo	1 aviso · hallazgo 4
Código y lógica	Semgrep 1.177	1.494 líneas propias, contra 104 reglas automáticas	sin hallazgos
Secretos	Gitleaks 8.30	las 66 versiones guardadas del proyecto, desde la primera	sin hallazgos

HALLAZGOS

1 La página aceptaba cualquier programa que llegara a ella

QUÉ SE ENCONTRÓ La página no declaraba de qué sitios podía cargar programas, así que el navegador ejecutaba cualquiera que apareciera en ella.	CÓMO PODÍA AFECTAR Si alguien lograba colar un programa —por ejemplo dentro de un archivo subido—, ese programa podía leer la captura de pantalla que la persona acababa de compartir y cambiar el veredicto que veía.	CORRECCIÓN Y PRUEBA Se declaró la lista de sitios permitidos. Prueba: se intentó cargar un programa desde un sitio ajeno. Bloqueado .
--	--	--

2 Los dos archivos que vienen de fuera no se verificaban

QUÉ SE ENCONTRÓ La página pedía dos programas prestados a servidores ajenos y aceptaba lo que esos servidores le devolvieran, sin comprobar que fuera el archivo esperado.	CÓMO PODÍA AFECTAR Si uno de esos servidores entregaba un archivo alterado, corría dentro de la página con los mismos permisos que el código propio, sin que nadie lo notara.	CORRECCIÓN Y PRUEBA Se guardó la huella del archivo verificado. Prueba: con huella falsa, descartado ; con la correcta, se ejecuta . El lector de imágenes sigue funcionando.
--	---	---

3 Cualquier sitio web podía usar el servidor del proyecto

QUÉ SE ENCONTRÓ El servidor atendía peticiones de cualquier origen. El tope de consultas por conexión funcionaba, pero podía rodearse.	CÓMO PODÍA AFECTAR Otro sitio podía incluir un programa que llamara al servidor desde el navegador de cada uno de sus visitantes. Mil visitantes son mil conexiones distintas: ninguna llega al tope y la capacidad diaria se agota para quien la necesita.	CORRECCIÓN Y PRUEBA El servidor solo autoriza al propio sitio. Prueba: desde un origen inventado, sin permiso ; desde constata.dev, con permiso .
--	---	---

4 Una biblioteca de desarrollo arrastra una vulnerabilidad conocida

QUÉ SE ENCONTRÓ La biblioteca sharp 0.35.2 , que llega como dependencia de la herramienta de despliegue, tiene una vulnerabilidad de severidad alta registrada.	CÓMO PODÍA AFECTAR Solo se usa en el equipo de desarrollo al construir el proyecto. No forma parte de lo que se publica ni llega al navegador de quien visita el sitio, así que haría falta que alguien ya tuviera acceso al equipo.	CORRECCIÓN Y PRUEBA Actualización a 0.35.4, dentro del plazo comprometido. Estado: pendiente . Es el único de los cuatro que no se ha aplicado.
--	--	--

REMEDIACIÓN

HALLAZGO	SEVERIDAD	FECHA DE APLICACIÓN	ESTADO
Programas no declarados en la página	Alta	17 sep 2026	Remediado
Archivos externos sin verificar	Alta	17 sep 2026	Remediado
Servidor abierto a cualquier origen	Media	17 sep 2026	Remediado
Dependencia sharp 0.35.2	Baja en este contexto	hasta el 17 nov 2026	Pendiente

Plazo comprometido para el conjunto: **17 de noviembre de 2026**. Las tres correcciones de severidad alta y media se aplicaron y verificaron el mismo día de la detección.